DORA

FINANCIAL RESILIENCE SCOPING ENGINE

Strategic Nexus

DORA Bank Resilience

Threat-Led Penetration Testing Scoping Document — Nexus v33.0

ENTITY	RESILIENCE INDEX	ENGAGEMENT DURATION	CLASSIFICATION
DORA Bank Resilience	80%	65 Days	Restricted

Financial Resilience Coverage Index

80

TLPT RESILIENCE INDEX

Financial Resilience Coverage Score

This score reflects the breadth of coverage across the four mandatory Threat-Led Penetration Testing pillars required under DORA Article 26, PRA CBEST, and HKMA iCAST.

TLPT COMPLIANCE PILLAR	COVERAGE STATUS
Threat Intelligence Profiling	VALIDATED
Covert Attack Emulation	VALIDATED
Purple Team Collaboration	VALIDATED
Executive Crisis Validation	GAP — MODULE NOT ENGAGED

Executive Resourcing & Schedule Summary

Executive Resourcing & Schedule Summary

The following summarizes the operational timeline and resourcing required to execute the defined Threat-Led Penetration Testing modules in alignment with regulatory mandates.

65
TOTAL ENGAGEMENT DAYS

13
EXECUTION WEEKS

4
TLPT PERSONNEL

3
ACTIVE MODULES

Automated TLPT Resourcing Allocation

ROLE	HEADCOUNT	TLPT RESPONSIBILITY	CLEARANCE
Threat Intel & Red Team Lead	1	Strategic oversight, regulatory coordination, TI report authorship, and final QA gate review.	Full Knowledge
Covert Red Team Operator	3	Technical execution, assumed breach operations, exploit development, and stealth persistence.	Full Knowledge
Purple Team Facilitator	1	Replay exercise facilitation, SOC detection tuning, and SIEM rule validation.	Full Knowledge
Client White Team	TBD	Kill-switch authority, CBS owner coordination, and regulatory notification.	Full Knowledge

1.5 Regulatory Alignment: DORA Bank Resilience

Narrative: DORA resilience and TLPT-ready scoping for critical ICT systems, functions, and third-party ICT dependencies.

REGULATORY BODY Digital Operational Resilience Act (DORA) (European Union)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Article 5	ICT Risk Management Framework	Firms must maintain a comprehensive, documented ICT risk management framework reviewed at least annually.	All critical ICT systems underpinning core financial functions.
Article 9	Protection & Prevention	Continuous monitoring and safeguarding of ICT systems; anomaly detection and prevention controls.	SIEM / SOC controls and detection capabilities under covert Red Team conditions.
Article 11	Business Continuity & Disaster Recovery	Firms must implement and test BCPs and DR plans for all critical functions.	RTO/RPO objectives tested via Purple Team replay and IR tabletop exercises.
Article 24	General ICT Testing Programme	Annual ICT resilience testing programme with risk-based scope.	All critical ICT systems and third-party ICT providers.
Article 26	Threat-Led Penetration Testing (TLPT)	Advanced TLPT required every 3 years for major financial entities. Mandates intelligence-led, covert, scenario-based Red Team testing.	Qualified external Red Team with regulatory oversight. TI-PHASE must precede RT-COVERT.
Article 28	ICT Third-Party Risk Management	Contractual obligations and exit strategies must be defined for all critical ICT third-party providers.	Cloud workloads, payment processors, and external ICT dependencies.
Article 30	Key Contractual Provisions	Contracts with ICT third parties must define SLAs, audit rights, and regulatory access provisions.	All contractual frameworks with critical ICT third-party service providers.

Mandatory Evidence Artifacts:

- Asset Register & CBS Map
- ICT Risk Register
- Threat Intelligence Profile
- TLPT Test Plan (Pre-Execution)
- TLPT Execution Report
- Remediation Plan & Timeline
- Third-Party ICT Risk Assessment

TIBER-EU Alignment & ESA Oversight

DORA Article 26 is underpinned by the TIBER-EU framework developed by the European Central Bank. Engagements must align with TIBER-EU's three-phase structure: Preparation (scoping & TI procurement), Test (covert Red Team execution), and Closure (reporting & remediation). The Joint Supervisory Team (JST) or relevant ESA (EBA/ESMA/EIOPA) must be notified prior to testing commencing on systemically important entities.

ICT Asset Criticality Mapping & CIF Declaration

Scoping must begin with a formally approved ICT Asset Register. Every asset in scope must be mapped to a Critical or Important Function (CIF) as defined under DORA Article 3. If an asset supports a CIF, it is subject to enhanced TLPT requirements and must appear in the CBS register. Assets that cannot be mapped to a CIF must be formally excluded with documented justification.

Third-Party ICT Service Provider Authorization

DORA Article 28 mandates that contractual arrangements with critical ICT third-party providers include explicit clauses permitting security testing. This scoping pack must include a Third-Party Dependency Register and written confirmation from each relevant provider. Cloud service providers hosting critical workloads must provide a Letter of Authorization (LoA) before any testing commences.

Threat Intelligence Sourcing Requirements

For DORA-compliant TLPT, threat intelligence must be sourced from a provider meeting the TIBER-EU TI Provider requirements. Intelligence must be current (within 12 months), specific to the financial sector, and targeted to the institution's geopolitical threat landscape. Generic CTI feeds are insufficient — bespoke Targeted Threat Intelligence Reports (TTIRs) are required.

Evidence & Artifact Requirements (Annex Submission)

Upon closure, the following must be submitted to the relevant ESA: (1) Final TLPT Report, (2) Remediation Plan with tracked findings, (3) Letter of Attestation from the TLPT Cyber Team (TCT), and (4) Management Summary for Board consumption. All artifacts must be retained for a minimum of 5 years under DORA Article 26(8).

ATT&CK Financial Sector Threat Groups

Execution scenarios must reference specific MITRE ATT&CK threat groups active against the financial sector. Key groups include: FIN7 (T1566, T1078, T1071), Carbanak (T1059, T1105), Lazarus Group (T1190, T1133, T1486), and TA505 (T1566.001, T1204). Attack chains must be constructed using the ATT&CK Navigator to demonstrate coverage across Initial Access, Execution, Persistence, Privilege Escalation, and Exfiltration tactics.

Kill Chain Mapping & TTP Evidence

Each attack scenario must produce a formal Kill Chain map documenting the exact sequence of ATT&CK techniques employed. Evidence of each technique must be captured in the form of tool output, command history, and screenshots. The Kill Chain document forms a mandatory annex to the TLPT Final Report and must be provided to the regulator upon request.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021 — Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. For financial institutions, this specifically includes testing of role-based access controls on banking APIs, separation of duties in payment authorization workflows, and privilege escalation paths on core banking administration interfaces.

A02:2021 — Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. For regulated financial data, this includes PAN data (PCI-DSS scope), customer PII, and interbank settlement data. Weak cipher suites, expired TLS certificates, and improperly stored credentials must all be tested.

A10:2021 — Server-Side Request Forgery (SSRF)

SSRF vulnerabilities are particularly dangerous in financial API environments as they can allow an attacker to pivot from a public-facing API to internal payment infrastructure. All public-facing Open Banking APIs must be tested for SSRF to prevent lateral movement from external to internal payment networks.

IMPLEMENTATION GUIDANCE

CIS

Control 1 & 2: Asset & Software Inventory

Actively manage all enterprise assets and software. For TLPT engagements, the CBS Register serves as the asset inventory baseline. Any asset discovered during the Red Team execution that was not in the CBS Register must be flagged as a shadow IT finding and reported as a governance gap.

Control 6: Access Control Management

Testing must validate privileged access management (PAM) controls, MFA enforcement on all privileged accounts, and the absence of default or shared credentials on network devices and servers.

Control 17: Incident Response Management

The Purple Team replay exercises must test the institution's incident response capabilities against the CIS Control 17 framework, measuring time-to-detect, time-to-contain, and time-to-recover against the defined TLPT attack scenarios.

Framework Specific Guidance

DORA Implementation Guidance

TIBER-EU Alignment & ESA Oversight

DORA Article 26 is underpinned by the TIBER-EU framework developed by the European Central Bank. Engagements must align with TIBER-EU's three-phase structure: Preparation (scoping & TI procurement), Test (covert Red Team execution), and Closure (reporting & remediation). The Joint Supervisory Team (JST) or relevant ESA (EBA/ESMA/EIOPA) must be notified prior to testing commencing on systemically important entities.

ICT Asset Criticality Mapping & CIF Declaration

Scoping must begin with a formally approved ICT Asset Register. Every asset in scope must be mapped to a Critical or Important Function (CIF) as defined under DORA Article 3. If an asset supports a CIF, it is subject to enhanced TLPT requirements and must appear in the CBS register. Assets that cannot be mapped to a CIF must be formally excluded with documented justification.

Third-Party ICT Service Provider Authorization

DORA Article 28 mandates that contractual arrangements with critical ICT third-party providers include explicit clauses permitting security testing. This scoping pack must include a Third-Party Dependency Register and written confirmation from each relevant provider. Cloud service providers hosting critical workloads must provide a Letter of Authorization (LoA) before any testing commences.

Threat Intelligence Sourcing Requirements

For DORA-compliant TLPT, threat intelligence must be sourced from a provider meeting the TIBER-EU TI Provider requirements. Intelligence must be current (within 12 months), specific to the financial sector, and targeted to the institution's geopolitical threat landscape. Generic CTI feeds are insufficient — bespoke Targeted Threat Intelligence Reports (TTIRs) are required.

Evidence & Artifact Requirements (Annex Submission)

Upon closure, the following must be submitted to the relevant ESA: (1) Final TLPT Report, (2) Remediation Plan with tracked findings, (3) Letter of Attestation from the TLPT Cyber Team (TCT), and (4) Management Summary for Board consumption. All artifacts must be retained for a minimum of 5 years under DORA Article 26(8).

MITRE Implementation Guidance

ATT&CK Financial Sector Threat Groups

Execution scenarios must reference specific MITRE ATT&CK threat groups active against the financial sector. Key groups include: FIN7 (T1566, T1078, T1071), Carbanak (T1059, T1105), Lazarus Group (T1190, T1133, T1486), and TA505 (T1566.001, T1204). Attack chains must be constructed using the ATT&CK Navigator to demonstrate coverage across Initial Access, Execution, Persistence, Privilege Escalation, and Exfiltration tactics.

Kill Chain Mapping & TTP Evidence

Each attack scenario must produce a formal Kill Chain map documenting the exact sequence of ATT&CK techniques employed. Evidence of each technique must be captured in the form of tool output, command history, and screenshots. The Kill Chain document forms a mandatory annex to the TLPT Final Report and must be provided to the regulator upon request.

OWASP Implementation Guidance

A01:2021 — Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. For financial institutions, this specifically includes testing of role-based access controls on banking APIs, separation of duties in payment authorization workflows, and privilege escalation paths on core banking administration interfaces.

A02:2021 — Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. For regulated financial data, this includes PAN data (PCI-DSS scope), customer PII, and interbank settlement data. Weak cipher suites, expired TLS certificates, and improperly stored credentials must all be tested.

A10:2021 — Server-Side Request Forgery (SSRF)

SSRF vulnerabilities are particularly dangerous in financial API environments as they can allow an attacker to pivot from a public-facing API to internal payment infrastructure. All public-facing Open Banking APIs must be tested for SSRF to prevent lateral movement from external to internal payment networks.

CIS Implementation Guidance

Control 1 & 2: Asset & Software Inventory

Actively manage all enterprise assets and software. For TLPT engagements, the CBS Register serves as the asset inventory baseline. Any asset discovered during the Red Team execution that was not in the CBS Register must be flagged as a shadow IT finding and reported as a governance gap.

Control 6: Access Control Management

Testing must validate privileged access management (PAM) controls, MFA enforcement on all privileged accounts, and the absence of default or shared credentials on network devices and servers.

Control 17: Incident Response Management

The Purple Team replay exercises must test the institution's incident response capabilities against the CIS Control 17 framework, measuring time-to-detect, time-to-contain, and time-to-recover against the defined TLPT attack scenarios.

Threat Scenarios & Modeling

PART I.C: THREAT INTELLIGENCE

Threat Intelligence Profiles

> **MANDATORY REQUIREMENT PENDING:** A Threat Intelligence phase or report must be completed and formally appended to define the attack scenarios before Red Team or Intelligence-Led testing begins.

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Payload & Exploit Transmission	Zero-Knowledge End-to-End Encryption (E2EE)
Exfiltrated Data Storage	Ephemeral Air-Gapped Analysis Environment (256-bit AES)
Red Team Telemetry Retention	Secure SOC Aggregation (Strict 30-Day Limit)
Artifact Destruction	NIST 800-88 Compliant Cryptographic Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
DORA	All TLPT evidence and reporting artifacts must remain strictly within EU boundaries or approved adequate jurisdictions. Cloud storage requires EU-based tenants under GDPR compatibility.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
DORA	European Supervisory Authorities (ESAs) — EBA, ESMA, and EIOPA — must have full, unrestricted, and on-demand access to all TLPT results, threat intelligence profiles, and remediation evidence.

Operational Team Governance

PART II.A: TEAM STRUCTURE

STRICTLY CONFIDENTIAL // STRATEGIC SCOPE

White Team & Control Group Structure

In accordance with intelligence-led frameworks (CBEST/iCAST), the engagement must be overseen by a strictly segregated Control Group to ensure operational safety without alerting the defensive Blue Team.

GOVERNANCE BODY	REGULATORY RESPONSIBILITY	CLEARANCE LEVEL
The White Team	Engagement sponsors holding the emergency Kill-Switch. Responsible for defining the Critical Business Services (CBS) and Impact Tolerances.	Full Knowledge
The Control Group	A trusted subset of the client's internal IT/Security team who monitor the engagement for safety but do not participate in defense.	Full Knowledge
The Blue Team	The operational SOC and incident responders who must defend the network as if under a real attack.	Zero Knowledge
Threat Intel Provider	Independent vendor supplying the threat landscape profiles and attack scenarios to the Red Team.	Execution Phase
Covert Red Team	The execution unit simulating the Threat Actor's TTPs against the CBS.	Execution Phase

Critical Business Services & Impact Tolerance

PART II.C: CBS IMPACT TOLERANCE

Critical Business Services (CBS) Scope

⚠ **ACTION REQUIRED — CBS DECLARATION MISSING:** No Critical Business Services have been declared. Under DORA Article 26 and PRA CBEST, the client must map target infrastructure to its underlying business function and formally define the maximum impact tolerance before testing may begin.

Access & Test Data Readiness

> Standard testing prerequisites apply: Client must provide stable network access (VPN/Jump host), valid application credentials (min. 2 per role), and any required API documentation prior to the start of the testing window.

Third-Party ICT Supply Chain Scope

PART II.D: THIRD-PARTY RISK

Third-Party ICT Dependency Register

> No third-party ICT dependencies or hosted environments have been declared in scope. Testing is restricted to first-party infrastructure.

Technical Scope of Work

TI-PHASE — **Targeted Threat Intelligence Gathering**

Formally scoped intelligence gathering phase designed to identify threat actors, define attack scenarios, and produce the Threat Intelligence Profile required before Red Team execution.

Allocated Schedule: 15 Days

RT-COVERT — **Covert Red Team Execution**

Intelligence-led, objective-based penetration testing executing the scenarios defined in the TI-PHASE. Includes stealth, evasion, and assumed-breach scenarios against core financial systems.

Allocated Schedule: 40 Days

PT-REPLAY — **Purple Team Replay Exercises**

Collaborative replay of Red Team attack chains alongside the defensive Blue Team to validate SOC detections, incident response capabilities, and SIEM rule effectiveness.

Allocated Schedule: 10 Days

Execution Timeline (Gantt)

Financial Control Mapping (Omni Matrix)

The following TLPT-specific financial controls are in scope for the selected execution modules, mapped to their regulatory article references.

CONTROL ID	CONTROL NAME	FRAMEWORK	REGULATORY REFERENCE	IMPACT RATING
CB_01	Core Banking Network Segmentation	DORA	Art. 24 (TLPT)	**Critical**
CB_02	Retail Payment Infrastructure Isolation	DORA	Art. 26 (ICT Resilience)	**Critical**
SW_01	SWIFT Gateway Network Isolation	PRA CBEST	Objective A – Segregation	**Critical**
SW_02	SWIFT Messaging Integrity Validation	PRA CBEST	Objective B – Data Integrity	**Critical**
IAM_01	Privileged Access Management (PAM)	FRB	SR 13-1 – Access Control	**High**
IAM_02	Service Account Credential Hygiene	MAS TRM	Section 12.3 – IAM	**High**
IAM_03	Multi-Factor Authentication Enforcement	MAS TRM	Section 12.4 – Authentication	**High**
TI_01	Threat Intelligence Profile Development	HKMA iCAST	CFI 2.0 – TI Framework	**High**
TI_02	Threat Actor Attribution & Profiling	PRA CBEST	CBEST TI Module	**High**
TI_03	Attack Scenario Development (MITRE ATT&CK)	HKMA iCAST	CFI 2.0 – Scenario Modelling	**High**
TI_04	Threat-Led Defense Posture Assessment	HKMA iCAST	CFI-2 – Posture Review	**High**
IR_03	SOC Detection & SIEM Validation	MAS TRM	Section 13 – Incident Response	**High**
IR_04	Purple Team Replay & Remediation Verification	FRB	SR 11-7 – Model Validation	**Medium**
DR_02	RTO / RPO Objective Testing Under Load	FRB	SR 13-1 – Continuity	**High**
API_01	Open Banking API Security Boundary	MAS TRM	Section 12.1 – API Controls	**High**
CLD_01	Cloud Workload Lateral Movement Detection	DORA	Art. 30 – ICT Third-Party Risk	**High**

RACI Responsibility Assignment Matrix

Defines who is Responsible, Accountable, Consulted, and Informed for each TLPT activity across all parties.

ACTIVITY	THREAT INTEL PROVIDER	COVERT RED TEAM LEAD	CLIENT WHITE TEAM	CLIENT CONTROL GROUP	CLIENT SECURITY OPS (SOC)	CLIENT EXEC SPONSOR / CISO
Targeted Threat Intelligence Gathering	R	C	A	I	I	I
Attack Scenario & TTP Development	R	C	A	I	I	I
Critical Business Service (CBS) Declaration	I	I	A	C	C	R
Regulator & Scope Notification	I	C	A	I	I	R
White Team Briefing & Kill-Switch Assignment	I	C	R	C	I	A
Covert Red Team Execution (TLPT)	C	R	A	I	I	I
Emergency Kill-Switch Activation	I	C	R	C	I	A
Purple Team Replay Exercises	C	R	I	I	A	I
SOC Detection Rate Validation	I	C	A	C	R	I
Executive Crisis Management Tabletop	I	C	A	I	I	R
Remediation Planning & Sign-off	I	C	C	I	R	A
Regulator Artifact Submission	C	C	I	I	R	A

Regulatory Deliverables Schedule

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Digital Operational Resilience Act (DORA)	Asset Register & CBS Map
Digital Operational Resilience Act (DORA)	ICT Risk Register
Digital Operational Resilience Act (DORA)	Threat Intelligence Profile
Digital Operational Resilience Act (DORA)	TLPT Test Plan (Pre-Execution)
Digital Operational Resilience Act (DORA)	TLPT Execution Report
Digital Operational Resilience Act (DORA)	Remediation Plan & Timeline
Digital Operational Resilience Act (DORA)	Third-Party ICT Risk Assessment

Quality Assurance & Peer Review

PART IV.B: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

Engagement Sign-Off & Authorization

PART V: AUTHORIZATION

By signing below, the parties confirm that this Nexus Scoping Document has been reviewed and is accepted as the binding scope of work for the defined Threat-Led Penetration Testing engagement. This document satisfies the engagement scoping requirements for the active regulatory frameworks: **DORA, PRA CBEST, HKMA iCAST, FRB, and MAS TRM**.

SIGNATORY ROLE	FULL NAME	SIGNATURE	DATE
Client Executive Sponsor / CISO			
Client White Team Lead			
Red Team Lead (Provider)			
Threat Intelligence Lead (Provider)			

✓ **Document Control:** This document is classified **RESTRICTED**. Distribution is limited to parties named in the White Team register. Regulatory bodies retain audit rights as defined in Part II of this document.